

API Data Flow Reference

System overview

PetPals uses a two-token authentication system. Authentication credentials are centralised in a single USERS table shared across all six role-specific tables (Admin, Staff, Veterinarian, Adopter, Volunteer, Donor).

Token	Storage	Expiry	Purpose
Access token	Zustand memory (frontend)	15 minutes	Sent in Authorization header on every protected API request.
Refresh token	httpOnly cookie (browser)	7 days	Used only to issue new access tokens - never sent in API headers

Architecture pattern followed by every backend endpoint:

Route → Middleware (protected routes only) → Controller → Service → Database

Frontend auth pattern on every page load:

App.tsx mounts → refreshToken() called → httpOnly cookie sent → new access token returned → Zustand populated

1. Backend Auth API

Base path: /api/v1/auth

Four endpoints covering registration, login, logout, and token refresh. Register and login are public. Logout requires a valid Bearer access token. Refresh-token requires only the httpOnly cookie.

1.1 POST /api/v1/auth/register

Creates a new user account. Writes two rows atomically - one to USERS (credentials) and one to the role-specific table (name + userID). The Prisma \$transaction ensures both succeed or both roll back.

Request summary

Field	Value
Method	POST
Auth required	No - public endpoint
Body fields	name, email, password, role
Valid roles	admin, adopter, staff, vet, volunteer, donor
Success	201 - { userID, userEmail, role }

Data flow

File / Layer	What happens here
auth.routes.js	Receives POST request, no middleware – public route. Maps POST /register → register controller
auth.controller.js	Validates all 4 fields are present and role is one of the 6 valid values. Deconstructs { name, email, password, role } from req.body. Returns VALIDATION_ERROR (422) if any field is missing. Returns VALIDATION_ERROR (422) if role is not valid. Calls authService.register() in try/catch. On success: successResponse 201 with created user. On failure: next(err) → errorHandler
auth.service.js	Duplicate email check, bcrypt hash, atomic double-insert via Prisma transaction. findUnique on USERS by email - throws CONFLICT (409) if exists. bcrypt.hash(password, 10). Opens

	\$transaction: creates USERS row, then role-specific row using returned userID. If either insert fails, entire transaction rolls back - no orphaned records. Strips userPassword from returned object
USERS table	Stores auth credentials. Columns written: userEmail, userPassword (hashed), role
Role table	Stores name and userID for the specific role. Columns written: userID (FK → USERS), [role]Name (e.g. adopterName)

accountStatus at registration: accountStatus is now set explicitly for four of the six roles - Admin, Staff, Vet, and Volunteer - which start as “Pending” and require approval (via the PATCH .../status endpoints) before they can log in. Exception: the very first Admin ever registered in the system auto-activates as “Active” immediately, since there's no existing admin to approve them. Adopter and Donor registrations are unaffected - they still start “Active” by their own table defaults. Staff, Vet, and Volunteer choose a shelter at sign-up (shelterID is required). The first Staff sign-up at a shelter with no manager (and no pending Manager sign-up) registers as that shelter's Manager and is approved by an Admin; other staff are approved by that shelter's Manager. Staff onboard BEFORE approval: after registering, a Staff member is signed straight in by the worker-portal sign-up page and completes an onboarding wizard (personal details, address, government ID). Vet, Volunteer and Admin still wait for approval before they can sign in.

Error cases

Scenario	Error Code	Response Message
Missing any of the 4 fields	VALIDATION_ERROR	name, email, password, and role are required
Role not in the allowed list	VALIDATION_ERROR	role must be one of: admin, adopter, staff, vet, volunteer, donor
Email already registered	CONFLICT	A user with this email is already registered
DB insert fails	INTERNAL_SERVER_ERROR	Internal server error

1.2 POST /api/v1/auth/login

Authenticates an existing user. Verifies credentials against USERS, issues a 15m access token in the response body and a 7d refresh token in an httpOnly cookie. Also fetches the user's name from the role-specific table for UI display.

Request summary

Field	Value
Method	POST
Auth required	No - public endpoint
Body fields	email, password
Success	200 - { token (15m), user: { userID, userEmail, role, name, avatarSeed } } + refreshToken httpOnly cookie (7d)

Data flow

File / Layer	What happens here
auth.routes.js	Receives POST request, no middleware - public route. Maps POST /login → login controller
auth.controller.js	Validates fields, calls service, signs both tokens, sets cookie. Returns VALIDATION_ERROR (422) if email or password missing. Calls authService.login() in try/catch. Signs access token payload: { userID, role } for all roles, 15m expiry, JWT_SECRET. Signs refresh token: { userID }, 7d expiry, JWT_SECRET. Hashes refresh token with bcrypt and calls authService.storeRefreshToken(userID, hashedRT). Sets refreshToken as httpOnly cookie (sameSite: strict, secure in production). Returns 200 with { token: accessToken, user }

auth.service.js (login)	Verifies credentials, fetches name from role table, returns safe user object. findUnique on USERS by email (selects userID, userEmail, role, userPassword only). Throws NOT_FOUND (404) if no record. bcrypt.compare(password, user.userPassword) - throws UNAUTHORIZED (401) if no match. Queries role-specific table for the user's name using ROLE_CONFIG. Strips userPassword before returning { ...safeUser, name }
auth.service.js (storeRefreshToken)	Stores hashed refresh token in USERS table. prisma.users.update({ where: { userID }, data: { refreshToken: hashedRT } })
USERS table	Queried for credentials, updated with refresh token hash. Columns read: userEmail, userPassword. Columns written: refreshToken (hashed)
Role table	Queried for the user's display name. e.g. Adopter.adopterName, Staff.staffName etc. avatarSeed is also selected here for every role (not Staff-specific) and included in the returned user object.

Design note — shelterID is not in the token: the payload is { userID, role } for every role. Staff-scoped endpoints re-fetch the staff member's current shelterID from STAFF on each request, so a shelter reassignment takes effect immediately.

lastLoginAt lives on USERS and is updated on every successful login, for all roles.

Error cases

Scenario	Error Code	Response Message
Missing email or password	VALIDATION_ERROR	email and password are required
Email not found in USERS	NOT_FOUND	No account found with this email
Password does not match hash	UNAUTHORIZED	Incorrect password
Account status is Pending (Vet, Volunteer or Admin)	UNAUTHORIZED	This account is pending approval and can't log in yet.

Pending Staff can log in: login succeeds so they can onboard before approval, but authenticate only lets them reach their own onboarding endpoints (see 1.5). Success response: user also carries onboardingComplete and onboardingStep for Adopter and Staff, and accountStatus for Staff.

1.3 POST /api/v1/auth/logout

Ends the session by nullifying the stored refresh token in the DB and clearing the httpOnly cookie. The access token is not denylisted - with a 15-minute expiry the risk window is acceptable. The refresh token nullification is the source of truth for session invalidation.

Request summary

Field	Value
Method	POST
Auth required	Yes — Bearer access token (a Pending Staff member may log out too)
Body fields	None
Success	200 - { message: "Logged out successfully" }

Data flow

File / Layer	What happens here
auth.routes.js	Registers authenticate middleware before controller. Maps POST /logout to: authenticate → logout controller
authenticate.js	Validates the Bearer access token. Extracts token from Authorization header via optional chaining. Returns UNAUTHORIZED if missing. jwt.verify(token, JWT_SECRET) - throws if invalid or expired. Attaches { userID, role } to req.user and calls next()

auth.controller.js	Calls service with userID and clears the cookie. Uses req.user.userID (set by authenticate middleware). Calls authService.logout(userID) in try/catch. res.clearCookie('refreshToken') - removes httpOnly cookie from browser. Returns 200 with 'Logged out successfully'
auth.service.js	Nullifies stored refresh token in DB. prisma.users.update({ where: { userID }, data: { refreshToken: null } }). Any future refresh attempt will fail bcrypt comparison
USERS table	refreshToken column set to null. Columns written: refreshToken = null

Error cases

Scenario	Error Code	Response Message
No Authorization header	UNAUTHORIZED	Authentication failed - no token provided
Access token invalid or expired	UNAUTHORIZED	Authentication failed - invalid token

1.4 POST /api/v1/auth/refresh-token

Issues a new access token and rotates the refresh token. Does not require an access token - authentication is via the httpOnly cookie only. Called by the frontend on every app load to restore session from the cookie.

Request summary

Field	Value
Method	POST
Auth required	No - cookie only (no Bearer token needed)
Cookie required	refreshToken httpOnly cookie
Body fields	None
Success	200 - { token (new access token, 15m), user: { userID, role, name, avatarSeed, onboardingComplete, onboardingStep (Adopter/Staff), accountStatus (Staff) } } + new refreshToken cookie (7d)

Data flow

File / Layer	What happens here
auth.routes.js	No middleware - cookie-only authentication handled in controller. Maps POST /refresh-token → refreshToken controller directly
auth.controller.js	Reads cookie, decodes userID from it, signs new tokens, calls service. Reads rawOldRT from req.cookies.refreshToken - returns UNAUTHORIZED if missing. jwt.decode(rawOldRT) to extract userID (no signature verification here). Returns UNAUTHORIZED if decoded.userID is absent. Signs new refresh token: { userID }, 7d expiry. Calls authService.refreshToken(userID, rawOldRT, newRefreshToken) in try/catch. On success: signs new access token payload { userID, role }, 15m expiry. Sets new refreshToken as httpOnly cookie. Returns 200 with new access token and { userID, role, name, avatarSeed }. Design note: this response object is built from an explicit field whitelist in the controller ({ userID, role, name } originally) - avatarSeed was silently dropped here even though authService.refreshToken() already returned it, until the whitelist itself was updated to include it. Any future field added to the service's return value must also be added to this whitelist explicitly, or it will be dropped without error.
auth.service.js	Verifies old refresh token against DB hash, stores new hash, fetches name and avatarSeed. findUnique on USERS by userID (selects userID, role, refreshToken). Throws NOT_FOUND if user missing. Throws UNAUTHORIZED if refreshToken in DB is null (already logged out). bcrypt.compare(rawOldRT, user.refreshToken) - throws UNAUTHORIZED if no match. bcrypt.hash(rawNewRT, 10) and updates USERS.refreshToken with new hash. Queries role-specific table for the user's name and avatarSeed using ROLE_CONFIG. Returns { userID, role, name, avatarSeed } (refreshToken stripped).
USERS table	refreshToken read for verification, updated with new hash. Columns read: refreshToken (hash for bcrypt comparison), role. Columns written: refreshToken (new hash)

Error cases

Scenario	Error Code	Response Message
No refreshToken cookie	UNAUTHORIZED	No refresh token provided
Cookie cannot be decoded	UNAUTHORIZED	Invalid refresh token
User not found in DB	NOT_FOUND	User not found
refreshToken null in DB (logged out)	UNAUTHORIZED	Session expired, please log in again
Cookie does not match DB hash	UNAUTHORIZED	Invalid refresh token

Design note - rotation

Each refresh token can only be used once. After a successful refresh the old hash is replaced in the DB. If an attacker steals a refresh token and tries to use it after the legitimate user has already rotated it, bcrypt.compare will fail and the request is rejected.

1.5 Live Account-Status Enforcement

A 15-minute access token previously stayed valid for its whole life regardless of what happened to the account after issuance - login() only ever blocked a fresh login attempt. middleware/authenticate.js now calls a new auth.service.js export, getAccountStatus(userID, role), on every single protected request (one indexed lookup on the role table's primary key) - not just at login/refresh. If the account's current status is Deactivated, Banned, Pending, or the sentinel “DELETED” (returned when the role's row no longer exists at all - e.g. after a completed self-delete), the request is rejected with 401 UNAUTHORIZED, message “This account is no longer active”, even if the JWT signature and expiry are otherwise perfectly valid. This closes the gap across every role and every protected route: an admin banning an adopter, deactivating a staff member, or an account completing a self-delete now takes effect immediately, not after the access token naturally expires.

This is a live DB read added on top of the existing JWT verification step, not a replacement for it - signature/expiry checks still happen first.

Onboarding exception: authenticate.allowPendingStaff is a second variant of the middleware that also admits a Pending Staff account. Only these routes use it: GET/PUT /staff/me, GET/POST /staff/me/government-id, PATCH /staff/me/onboarding-step, PATCH /staff/me/onboarding-complete and POST /auth/logout. Every other route keeps plain authenticate, so a Pending staff member gets 401 everywhere else. Approving that account then requires completed onboarding and a Verified government ID.

2. Backend Supporting Files

Shared across all auth endpoints

File	Purpose
config/prisma.js	Singleton Prisma client using PrismaPg adapter. Single gateway to the DB - imported by all service files.
utils/response.js	successResponse() and errorResponse() - standardise all API response shapes.
utils/errors.js	ERROR_CODES map - defines valid error codes and their HTTP status codes (400, 401, 403, 404, 409, 422, 500).
middleware/errorHandler.js	Global error handler registered last in app.js. Receives errors via next(err), maps err.code to HTTP status, formats using errorResponse().
middleware/authenticate.js	JWT verification middleware, now expanded beyond pure signature checking. Extracts Bearer token, verifies signature, attaches { userID, role } to req.user - then calls authService.getAccountStatus(userID, role) and rejects with 401 if the account is Deactivated, Banned, Pending, or DELETED (see 1.5). Used on logout. Not used on refresh-token. Also exports authenticate.allowPendingStaff (see 1.5).
middleware/authorizeRoles.js	RBAC middleware. Takes ...allowedRoles, checks req.user.role against the list, returns 403 FORBIDDEN if not permitted. Applied to role-specific endpoints in Sprint 2+.

app.js	Express app setup - middleware, routes, error handler. No app.listen() call. Imported by tests directly.
index.js	Thin entry point - requires app.js and calls app.listen(). Split from app.js to allow Supertest to import the app without binding a port.

3. Backend Supporting Files — client/src | Sprint 1

The frontend auth system is built around four files that each have a single responsibility. They are intentionally decoupled - the API layer knows nothing about state, the state layer knows nothing about HTTP, and the UI layer composes both.

3.1 File responsibilities

File	Responsibility
api/authApi.ts	API functions for auth endpoints - register(), login(), refreshToken(), logout(). Each makes an axios call and returns typed data. Knows nothing about state.
api/axiosInstance.ts	Pre-configured axios client. Sets baseUrl from VITE_API_URL env variable, withCredentials: true (sends httpOnly cookie automatically). Request interceptor attaches Bearer token from Zustand. Response interceptor handles 401 (clear state + redirect to the login page for the role: /staff-portal/login for Admin/Staff/Veterinarian, /login otherwise) and 403 (redirect to /forbidden), skipping auth endpoints to avoid redirect loops.
store/useAuthStore.ts	Zustand global store. Holds { user, token, role } in memory. login() sets all fields, logout() clears them. State is lost on page refresh - restored via refreshToken() on app load.
App.tsx	Root component. On mount, calls refreshToken() to restore session from the httpOnly cookie. On success, populates Zustand. On failure, does nothing - user will see public pages or be redirected to /login by ProtectedRoute. Uses authReady state to prevent flash of unauthenticated content.

3.2 Session restore on page load

Because Zustand state is memory-only, it is lost on every page refresh. The session is restored using the httpOnly cookie which persists across refreshes.

Flow

File / Layer	What happens here
App.tsx	useEffect fires on mount, calls refreshToken(). authReady state starts false - renders a rose background placeholder to prevent flash. refreshToken() called - axiosInstance sends the request with credentials: true. Browser automatically attaches the httpOnly refreshToken cookie
axiosInstance.ts	Sends POST /auth/refresh-token with withCredentials: true. isAuthCall guard on response interceptor prevents redirect loop if this call returns 401
Backend /auth/refresh-token	Verifies cookie, rotates tokens, returns new access token + name. New refreshToken set as httpOnly cookie in response. Returns { token, user: { userID, role, name } }
App.tsx .then()	On success, populates Zustand and sets authReady = true. storeLogin(user, token, user.role) - stores session in memory. authReady = true - full app renders, Navbar shows user name and dropdown
App.tsx .catch()	On failure (no cookie, expired), silently ignored. authReady = true - app renders normally. User sees public pages; ProtectedRoute redirects to /login if they try to access a dashboard

3.3 Login flow (Login.tsx)

File / Layer	What happens here
Login.tsx	Validates fields client-side, calls authApi.login(), updates Zustand, navigates. emailRegex validation + required field check before hitting API. noValidate on form - browser validation

	suppressed, custom error box used. On success: if a ?redirect= param is present, go there (unless it points into another role's dashboard); otherwise go to the role's dashboard via resolveDestination (Veterinarian → /vet). replace: true prevents back button returning to login page. On failure: displays server error message inline. If user already authenticated (token in Zustand): <Navigate> redirect away from login immediately
authApi.ts (login)	POSTs { email, password } to /auth/login. Returns { token, user: { userID, userEmail, role, name } }. axiosInstance automatically receives and stores the httpOnly refreshToken cookie

3.4 Logout flow (Navbar.tsx)

File / Layer	What happens here
Navbar.tsx (handleLogout)	Calls the API, then leaves and clears the session in ONE render via useEndSession (flushSync around navigate + storeLogout) — clearing the session first would let ProtectedRoute capture the current page as a stale /login?redirect. Destination by role: Admin, Staff and Veterinarian → /staff-portal/login; everyone else → /.
authApi.ts (logout)	POSTs to /auth/logout with Bearer token from Zustand. axiosInstance request interceptor attaches Authorization: Bearer <token> automatically

4. Role-Based Access Control — Frontend guards + backend middleware

PetPals enforces RBAC at two layers - the frontend prevents unauthenticated or wrong-role navigation, and the backend enforces the same rules on every API request. Both must be in place: frontend guards are UX, backend enforcement is security.

4.1 Frontend route guards

ProtectedRoute

Wraps any route that requires authentication. Reads token from Zustand - if absent, redirects to /login?redirect=<path> — or to /staff-portal/login?redirect=<path> for worker dashboards (/staff, /admin, /vet). If present, renders children.

Usage: <ProtectedRoute><AdopterDashboard /></ProtectedRoute>

RoleRoute

Wraps routes that require a specific role. Accepts an allowedRoles prop. Reads role from Zustand - if role is not in the allowed list, redirects to /forbidden. Used inside ProtectedRoute.

Usage: <ProtectedRoute><RoleRoute allowedRoles={['Adopter']}><AdopterDashboard /></RoleRoute></ProtectedRoute>

OnboardingGate

Wraps every route. An Adopter or Staff member with unfinished onboarding is sent to their current wizard step; a Staff member who has finished onboarding but is still Pending is held on /staff/pending (awaiting approval) until approved.

Route configuration in App.tsx

Route	ProtectedRoute	RoleRoute allowedRoles
/adopter	Yes	Adopter
/staff	Yes	Staff
/vet	Yes	Veterinarian

/volunteer	Yes	Volunteer
/donor	Yes	Donor
/admin	Yes	Admin
/login	No (redirects if already logged in)	-
/register	No (redirects if already logged in)	-
/forbidden	No	-

4.2 Backend RBAC middleware

authorizeRoles.js

Factory middleware that accepts a list of allowed roles and returns an Express middleware function. Called after authenticate so req.user.role is already set.

```
Usage: router.post('/pets', authenticate, authorizeRoles('Staff', 'Admin'),
createPet)
```

Applied to every protected resource endpoint.

ROLES constant

Key	Value (DB enum)
ROLES.ADMIN	Admin
ROLES.STAFF	Staff
ROLES.ADOPTER	Adopter
ROLES.VETERINARIAN	Veterinarian
ROLES.VOLUNTEER	Volunteer
ROLES.DONOR	Donor

4.3 Forbidden page

A simple public page at /forbidden rendered when RoleRoute or the axiosInstance 403 handler redirects an authenticated user who lacks the required role. Uses the same background image and card style as the login page.

Triggered by: RoleRoute (wrong role on frontend route) and axiosInstance response interceptor (403 from any API call).

5. Auth System Tests — Jest + Supertest | Sprint 1

Test file	Type	Cases covered
tests/unit/authenticate.test.js	Unit	No token → 401, Invalid JWT → 401, Expired JWT → 401, Valid JWT → sets req.user and calls next(), allowPendingStaff admits only Pending Staff
tests/unit/authorizeRoles.test.js	Unit	Role in allowedRoles → next(), Role NOT in allowedRoles → 403, Multiple allowed roles each pass
tests/unit/auth/login.test.js	Unit	Pending Staff login and refresh → 200 with accountStatus and onboarding progress; Pending Vet/Volunteer/Admin → 401
tests/integration/auth.register.test.js	Integration	Valid payload → 201 + DB rows created, Missing fields → 422, Duplicate email → 409, Password hashed in DB
tests/integration/auth.login.test.js	Integration	Valid credentials → 200 + JWT, Wrong password → 401, Unregistered email → 404, JWT contains correct userID and role
tests/integration/	Integration	Valid token → 200 + DB refreshToken null, Stale refresh token

auth.logout.test.js		after logout → 401, No token → 401
tests/integration/ auth.refreshToken.test.js	Integration	Valid cookie → 200 + new JWT
tests/integration/staff/ staffOnboarding.journey.test.js	Integration	Sign up → Pending login → onboard → ID verified → manager approves → full access

All integration tests seed data via the real register/login endpoints and clean up via Prisma in afterAll. Tests run sequentially (--runInBand) to avoid FK conflicts on the shared Supabase dev DB.